

Modelo de Encuesta Integral CAASM

Gestión de la Superficie de Ataque de Activos Cibernéticos

Objetivo: medir el grado de adopción, madurez y eficacia de capacidades CAASM en organizaciones españolas, con referencia a tendencias internacionales, marcos regulatorios (NIS2, ENS, ISO 27001, NIST, GDPR, DORA, etc.) y mejores prácticas de gestión de exposición.

0. Datos generales de la organización

1. Sector principal de actividad
2. Administración Pública
3. Sanidad
4. Energía / Utilities
5. Servicios financieros
6. Industria / Manufactura
7. Transporte y logística
8. TIC / Servicios digitales
9. Educación / Investigación
10. Otros (especificar): _____
11. Tamaño de la organización (empleados)
 12. Micro (≤ 10)
 13. Pequeña (11–50)
 14. Mediana (51–250)
 15. Grande (251–1.000)
 16. Muy grande (> 1.000)
17. Rol principal de la persona que responde
 18. CISO / Responsable máximo de seguridad
 19. Responsable de continuidad / resiliencia
 20. Responsable de infraestructura / operaciones
 21. Responsable de cumplimiento / legal
 22. Responsable de riesgos (ERM/ORO)
 23. Otro (especificar): _____
24. Alcance geográfico de la organización
 25. Local / regional
 26. Nacional
 27. Multinacional con sede en España
 28. Multinacional sin sede principal en España

Otros (especificar): _____

Tamaño de la organización (empleados)

Muy grande (> 1.000)

Rol principal de la persona que responde

Otro (especificar): _____

Alcance geográfico de la organización

1. Visibilidad y cobertura de activos

1.1 Inventario y descubrimiento

1.1.1. ¿Qué grado de confianza tiene en que el inventario de activos refleja la realidad viva de su superficie de ataque (TI, OT, IoT, nube, identidades, APIs)?

- Casi total: el inventario se alimenta automáticamente desde múltiples fuentes y se valida de forma continua.

- Alta: existen varias fuentes integradas, aunque persisten algunas “islas” tecnológicas.

- Limitada: sabemos que hay “zonas oscuras” significativas (por ejemplo, nube, OT, dispositivos remotos).

- Muy baja: el inventario es básicamente declarativo y ocasional, más cercano al deseo que a la topografía.

1.1.2. ¿Con qué frecuencia se detectan activos “sorpresa” (no inventariados) en auditorías, pentests o escaneos externos?

- Rara vez (menos de una vez al año).

- Ocasionalmente (1–2 veces al año).

- Con frecuencia (trimestralmente).

- Sistemáticamente: cada revisión descubre fauna tecnológica inédita.

1.1.3. ¿Dispone su organización de una plataforma específica de CAASM o capacidades equivalentes de descubrimiento y consolidación de activos?

- Sí, una plataforma CAASM dedicada en producción.

- Sí, capacidades CAASM integradas en otra solución (XDR, ASM, etc.).

- En piloto o fase de pruebas.

- No, pero estamos evaluando soluciones.

- No, ni se le espera (al menos de momento).

1.1.4. Fuentes integradas en su inventario de activos (marque todas las que apliquen):

- CMDB / ITSM

- Herramientas EDR/XDR

- Herramientas de gestión de vulnerabilidades

- Plataformas de nube (IaaS/PaaS/SaaS)

- Directorios e IAM (AD, IdP, SSO, etc.)
- Sistemas OT / SCADA / DCS
- Inventario manual / hojas de cálculo
- Otros (especificar): _____

1.2 Cobertura por dominios

1.2.1. ¿Cómo calificaría la visibilidad de activos TI tradicionales (servidores, PCs, portátiles, dispositivos de red)?

- Completa y actualizada de forma continua.
- Buena, con alguna laguna puntual.
- Parcial, con áreas opacas conocidas.
- Fragmentaria, con dependencia de inventarios manuales.

1.2.2. ¿Y la visibilidad de activos en nube (IaaS/PaaS/SaaS)?

- Completa, integrada en el inventario central mediante CAASM o similar.
- Buena, aunque existen cuentas o suscripciones poco controladas.
- Limitada a entornos principales; el resto vive en el limbo de la experimentación.
- Muy limitada: apenas hay inventario sistemático de recursos en nube.

1.2.3. ¿Visibilidad sobre APIs y servicios expuestos (internos y externos)?

- Tenemos un catálogo actualizado y supervisado.
- Existe un catálogo parcial, con APIs “históricas” poco controladas.
- Nos guiamos por la memoria colectiva y el registro de incidencias.
- Las APIs son criaturas mitológicas: sabemos que existen, pero no tenemos censo.

1.2.4. En cuanto a OT / entornos industriales (si aplican):

- Inventario detallado y actualizado, integrado con IT.
- Inventario razonable pero con esfuerzo manual elevado.
- Inventario parcial, centrado en activos más críticos.
- No existe un inventario formal de OT (o no aplica).

2. Higiene de seguridad y controles

2.1 Controles mínimos por activo

2.1.1. ¿Qué porcentaje aproximado de sus activos **críticos** cuenta con todos los controles exigidos (EDR/XDR, parches al día, cifrado cuando aplica, MFA, segmentación adecuada)?

- ≥ 90 % (lo que falta tiene fecha de jubilación o plan de mitigación claro).
- 70–89 % (las brechas están identificadas y priorizadas).
- 40–69 % (sabemos qué falta, pero la realidad operativa y presupuestaria manda).
- < 40 % (nuestra principal estrategia defensiva es la esperanza).

2.1.2. ¿Cómo verifica la organización la presencia real de dichos controles en los activos?

- Mediante CAASM u otras herramientas que validan automáticamente la existencia y estado de controles.

- Mediante correlación manual entre distintas herramientas (inventario, EDR, parcheo, etc.).
- Principalmente a través de auditorías periódicas y muestreos.
- Confiamos en que, si nadie se queja, los controles siguen ahí.

2.1.3. ¿Qué grado de alineamiento existe entre la criticidad de un activo (según negocio) y el nivel de controles aplicados?

- Elevado: la protección se ajusta de forma coherente a la criticidad.
- Aceptable: hay algunos activos sobreprotegidos o infraprotegidos.
- Bajo: la distribución de controles es más histórica que basada en riesgo.
- Desconocido: no existe una clasificación formal de criticidad de activos.

2.2 Zero Trust y gestión de identidades

2.2.1. Respecto a la adopción de un modelo Zero Trust apoyado en visibilidad de activos e identidades:

- Modelo avanzado: políticas dinámicas basadas en identidad, contexto y postura de dispositivo.
- Despliegue en curso: pilotos activos en múltiples dominios (nube, VPN, OT sensible, etc.).
- En planificación: existe una estrategia documentada pero con despliegue limitado.
- En contemplación filosófica: aparece en presentaciones, pero no en la topología de red.

2.2.2. ¿Qué grado de visibilidad tiene sobre identidades privilegiadas y sus activos asociados (servidores, aplicaciones, entornos cloud)?

- Alta: existe trazabilidad sistemática y correlación con CAASM/ASM.
- Media: se dispone de listados razonablemente actualizados.
- Baja: la información es fragmentaria, distribuida en diferentes equipos.
- Muy baja: las cuentas privilegiadas se descubren a menudo durante incidentes.

3. Exposición y riesgo material

3.1 Exposición externa e interna

3.1.1. ¿Dispone de una visión consolidada de todos los servicios expuestos a Internet (propios y de terceros críticos)?

- Sí, mediante CAASM/ASM integrados en el inventario.
- Parcialmente: sólo para dominios y rangos principales.
- Limitada: se actualiza periódicamente, pero no de forma continua.
- Prácticamente inexistente: cada pentest trae nuevas revelaciones.

3.1.2. ¿Cómo caracteriza la exposición de activos OT/IoT conectados a redes corporativas o externas?

- Claramente identificada y segmentada con políticas estrictas.
- Parcialmente controlada, con excepciones por requisitos operativos.
- Difusa: existen conexiones de las que no se tiene un mapa completo.
- No aplica / no se dispone de visibilidad estructurada.

3.1.3. En términos de API y servicios web expuestos, ¿qué afirmación describe mejor su situación?

- Todas las APIs y servicios públicos están catalogados, supervisados y sometidos a pruebas de seguridad regulares.

- Hay un catálogo parcial, con servicios “legados” poco revisados.
- Se catalogan los servicios principales; el resto vive en la periferia.
- El inventario de APIs crece más rápido que la documentación.

3.2 Priorización de vulnerabilidades y exposiciones

3.2.1. Al priorizar remediaciones, ¿qué peso real tiene la probabilidad de explotación (modelos como EPSS, inteligencia de amenazas) frente a la mera severidad técnica (CVSS)?

- Predomina la probabilidad de explotación y el contexto de negocio.
- Se combinan ambas, con prevalencia de CVSS en discusiones urgentes.
- La severidad técnica es el criterio de facto (CVSS como evangelio).
- El criterio de priorización real es “lo que se puede tocar sin romper producción”.

3.2.2. ¿Utiliza su organización fuentes externas de inteligencia de amenazas para ajustar la priorización de exposiciones identificadas por CAASM/ASM?

- Sí, de forma sistemática y automatizada.
- Sí, pero principalmente para casos de alto impacto mediático.
- Ocasionalmente, según disponibilidad del equipo.
- No, el mundo exterior nos visita solo vía noticias de brechas ajenas.

3.2.3. ¿Con qué frecuencia se revisan las reglas y modelos de priorización (por ejemplo, ponderación por criticidad de negocio, probabilidad de explotación, exposición externa)?

- Al menos trimestralmente.
- Una o dos veces al año.
- De forma ad hoc, tras incidentes significativos.
- No se revisan de forma formal; sobreviven las reglas históricas.

4. Remediación, automatización y resiliencia

4.1 Tiempos de remediación

4.1.1. Tiempo medio de mitigación de exposiciones **críticas** (no solo parcheo, sino cierre efectivo de la ventana de ataque):

- Menos de 7 días.
- Entre 7 y 30 días.
- Entre 1 y 3 meses.
- Más de 3 meses (o indefinido).

4.1.2. Tiempo medio de mitigación de exposiciones **altas**:

- Menos de 30 días.
- Entre 30 y 90 días.
- Entre 3 y 6 meses.
- Más de 6 meses / no definido.

4.1.3. ¿Qué porcentaje aproximado de exposiciones críticas se resuelve dentro de los plazos definidos por sus SLA internos o regulatorios?

- ≥ 90 %
- 70–89 %
- 40–69 %
- < 40 %
- No existen SLA formalmente definidos.

4.2 Automatización y flujo de trabajo

4.2.1. Grado de automatización en la remediación de exposiciones identificadas (parqueo, cambios de configuración, controles adicionales, etc.):

- Alto: uso extensivo de automatización (SOAR, playbooks, scripts integrados).
- Moderado: automatización para casos comunes, resto manual.
- Bajo: intervenciones mayoritariamente manuales y coordinadas por tickets.
- Nulo: la remediación es artesanal y evento a evento.

4.2.2. Integración de CAASM/ASM con herramientas de ticketing/ITSM:

- Integración bidireccional automática (creación y actualización de tickets).
- Integración unidireccional (creación de tickets, seguimiento manual).
- Integración parcial o a través de procesos manuales.
- No existe integración explícita.

4.2.3. ¿Con qué frecuencia se revisa la efectividad de los procesos de remediación (por ejemplo, análisis de exposiciones recurrentes, causas raíz, cuellos de botella)?

- Mensualmente.
- Trimestralmente.
- Anualmente.
- Solo tras incidentes que “duelen” especialmente.

5. Cumplimiento regulatorio y reporting

5.1 Uso de CAASM para cumplimiento

5.1.1. ¿Hasta qué punto utiliza su organización CAASM o herramientas equivalentes para obtener evidencias continuas de cumplimiento (ENS, NIS2, GDPR, ISO 27001, DORA, etc.)?

- Es la fuente principal de evidencias y reporting continuo.
- Se utiliza como complemento a auditorías y revisiones manuales.
- Uso parcial, centrado en algunos dominios (por ejemplo, nube o endpoints).
- No se utiliza CAASM para cumplimiento, sólo para gestión técnica.

5.1.2. ¿Dispone de trazabilidad entre controles de seguridad implementados y requisitos de marcos normativos o estándares?

- Sí, existe un mapeo formal mantenido y revisado periódicamente.
- Sí, pero está incompleto o desactualizado.
- Parcial, limitado a ciertos marcos (por ejemplo, ENS o ISO).
- No existe un mapeo estructurado; se trabaja caso por caso.

5.1.3. ¿Con qué frecuencia se generan informes ejecutivos sobre superficie de ataque y exposición de activos para la alta dirección o el consejo?

- Mensualmente o con mayor frecuencia.
- Trimestralmente.
- Anualmente.
- Solo cuando hay incidentes relevantes (o auditorías).

6. Gobernanza, estrategia y cultura

6.1 Estrategia CAASM y risk-based

6.1.1. ¿Existe una estrategia formalizada que incluya CAASM o gestión de superficie de ataque como componente explícito?

- Sí, documentada y aprobada por la alta dirección.
- Parcial, recogida en documentos de seguridad o arquitectura.
- En elaboración.
- No, pero se tratan aspectos de forma táctica.

6.1.2. ¿Cómo se integra la información de CAASM/ASM en el proceso de gestión de riesgos corporativos?

- Integración estructurada: la información nutre el mapa de riesgos y las decisiones de inversión.
- Integración moderada: influye en decisiones técnicas, pero poco en decisiones estratégicas.
- Integración limitada: aparece en informes, pero con impacto marginal.
- Prácticamente ninguna integración: son mundos paralelos.

6.2 Colaboración y cadena de suministro

6.2.1. ¿Comparte su organización información sobre su superficie de ataque o exposiciones relevantes con clientes, proveedores o autoridades (CSIRT nacional, sectoriales, etc.)?

- Sí, de manera estructurada y periódica.
- Sí, pero sólo en contextos específicos (incidentes, auditorías, requerimientos).
- Ocasionalmente, según las circunstancias.
- No, salvo obligación legal.

6.2.2. ¿Evalúa la superficie de ataque y la higiene de seguridad de terceros críticos (proveedores, socios, servicios externalizados)?

- Sí, de forma continua, con métricas y revisiones periódicas.
- Sí, aunque principalmente en procesos de homologación o contratación.
- De forma puntual y reactiva.
- No de manera sistemática.

7. Perspectiva de futuro y autocrítica constructiva

7.1. ¿Cuál es su principal prioridad en materia de superficie de ataque para los próximos 12–24 meses?

- Mejorar la visibilidad e inventario de activos (incluyendo nube, APIs, OT).
- Reducir la exposición externa y endurecer servicios críticos.
- Acelerar la remediación y automatizar más procesos.

- Integrar CAASM con gestión de riesgos y reporting ejecutivo.
- Sobrevivir a la suma de NIS2, ENS, DORA y lo que venga.

7.2. Si tuviera que describir en una frase el estado actual de su gestión de la superficie de ataque, ¿cuál sería?

- Respuesta abierta.

7.3. Comentarios adicionales, confesiones técnicas o deseos de reforma digital:

- Respuesta abierta.

Fin del modelo de encuesta.